APP SECURITY · ADMIN ACCESS

Hid the admin button? Still open.

A 2-minute check for any app with an admin area.

Swipe →

WHAT HAPPENS



app.example.com/admin

The button is gone from the menu, but anyone who **types the address** or **calls the API** still gets in.

Example, made up.

WHY



The UI decides. The server doesn't.

Hiding a link is a **frontend** decision. If the server never checks who is asking, it serves **anyone** who sends the request.

WHAT OWASP SAYS



Never trust client-side checks.

“Developers must never rely on client-side access control checks.” Access control has to be checked **on the server**.

OWASP Authorization Cheat Sheet



One regular test account.

Log in as a normal user and open the admin page address directly.
403 / not allowed = good. **The page loads** = it's open.

THE FIX



Deny by default.

```
if (!user.isAdmin)
  return 403
```

On the server, on **every request**, including the API endpoints behind the admin page.

OWASP Authorization Cheat Sheet: deny by default, validate on every request

BUILT YOUR APP WITH AI?

I'll take a look at it.

Send me a message. And follow for more checks like this.